

基于 QLoRA 微调 Qwen3-4B 的加密代码安全审计模型

——四轮迭代训练与评估实验报告

AI-Assisted Cryptographic Code Security Auditor

2026 年 9 月 13 日

摘要

本报告总结了一个面向 Python 加密代码的安全审计模型的四轮微调实验。系统以 **Semgrep 密码规则（10 条 CRYPTO 规则）** 作为静态候选生成器，以 **QLoRA 微调的 Qwen3-4B** 作为语义判别器，覆盖 **detect**（函数级「是否漏洞 + CWE + 严重度」）与 **triage**（finding 级 Confirm/Reject 分流 + 修复）两类任务。四轮实验围绕一条主线展开：第一轮建立双任务基线；第二轮仅对 triage 增量续训引发**灾难性遗忘**；第三轮改从基座全量合并重训并恢复能力；第四轮针对 detect 层「近乎全报」的过报问题引入负样本微调。实验表明：全量重训路线稳定，但第四轮的合成负样本扩量**未能消除 detect 过报**，增量续训路线再次出现遗忘，真实密码项目验证集上两个第四轮模型均未达标。报告详细记录各轮目标、数据构成、训练超参与评估结果，并对根因与后续方向给出分析。

目录

1	引言	2
2	系统与方法	3
2.1	整体架构	3
2.2	数据来源与构成	3
2.3	训练配置	3
2.4	评估协议（「三件套」+ 真实项目）	4
3	四轮训练历程	4
3.1	第一轮：双任务初次微调（建立基线）	4
3.2	第二轮：triage 增量续训（灾难性遗忘）	4
3.3	第三轮：全量合并重训（能力恢复）	5
3.4	第四轮：负样本微调 + 真实项目验证（未达预期）	5
4	结果汇总与横向对比	6

1 引言2

5 根因分析7

5.1 灾难性遗忘的反复出现7

5.2 合成负样本未带来泛化7

5.3 detect 层过报的根因未触及7

6 结论与展望7

6.1 结论7

6.2 下一步工作8

A 模型 ID 与关键文件索引8

1 引言

现代密码误用（MD5/SHA-1 口令散列、AES-ECB、硬编码密钥、弱随机源、弱 TLS 配置等）是 Web 与后端系统的高发缺陷类别。传统静态分析工具（如 Semgrep）能精确匹配已知的误用**模式**，却无法判断一次命中是否构成**真实安全缺陷**——例如密码库实现 DES/MD5 是为了兼容 legacy 格式，命中了规则却是「有效误报」（effective false positive）。本项目尝试用一个大语言模型填补这一语义鸿沟：用 QLoRA 在领域数据上微调 Qwen3-4B，使其在 Semgrep 静态命中之上完成漏洞判定、CWE 归类与误报分流。

项目采用**双任务**监督微调（SFT）范式，两类任务共享同一基座与统一输出 schema：

- **detect**（检测）：输入仅为代码，输出 {vulnerable, cwe, severity, confidence, explanation}；
- **triage**（分流）：输入为代码 + Semgrep finding，输出 {cwe, severity, verdict, explanation, patch}。

表 1 列出四轮实验产出的模型与基座对应关系，后文各节以轮次编号引用。

表 1：四轮实验模型清单（阿里云百炼 cn-beijing 部署端点）

轮次	模型 ID（后缀）	训练起点	数据 / 要点
基座	qwen3-4b-instruct-2507	—	Qwen3-4B-Instruct（未微调）
R1	...510facca98f1	基座	双任务初次微调（2538 条）
R2	...da015253d244	R1	triage 增量续训（54 条）
R3	...f5d4f1aedd8f	基座	全量合并重训（2595 条）
R4-微量	...d3eaeead171b	R3	77 负样本增量续训
R4-全量	...59e3a576c1e2	基座	50:50 负样本扩量重训（3315 条）

2 系统与方法

2.1 整体架构

系统的审计管线如图 1 所示（文本版）：

用户提交 Python 代码 → **Semgrep** (10 条自有 CRYPTO 规则, 候选 finding) → **LLM** (Base / 微调模型, 双任务) → 结构化 JSON → Markdown 安全报告

图 1: 审计管线 (Semgrep 静态候选 + LLM 语义判别)。

10 条密码规则与 CWE 映射如表 2。detect 任务输出 CWE 归类, triage 任务在规则命中之上给出 Confirm/Reject 判定与修复建议。

表 2: CRYPTO 规则与 CWE 映射

规则	主题	CWE
CRYPTO-001-005	MD5 / SHA-1 / DES / RC4 / AES-ECB	CWE-327 (弱加密)
CRYPTO-006	静态 IV	CWE-329
CRYPTO-007	硬编码密钥	CWE-321
CRYPTO-008	弱随机源	CWE-338
CRYPTO-009-010	弱密钥长度 / 弱 TLS	CWE-326

2.2 数据来源与构成

训练数据分三层（对应路线图 v2 的三层数据策略）：

- **L1 公共数据**：PyCode-Vul (Python 子集, cc-by-4.0) 官方 train/test 划分, 为 detect 主料。导入后 detect_train=2406 (1413 漏洞 / 993 安全)、detect_test=569 (305 漏洞 / 264 安全)；
- **L2 密码领域对照**：手写 + 模板变换的密码误用样本, 经自有规则回测, 构成 triage 数据与 domain_eval=29 (14 Confirm / 15 Reject, held-out)；
- **L3 真实项目**：5 个真实 Python 密码库 (itsdangerous / passlib / PyJWT / python-rsa / pycryptodome, 固定 commit) 构建的 42 条留出验证集。

样本统一为 chatml 格式 (scripts/prepare_sft_data.py::build_messages), 推理与训练共用同一 prompt 模板 (model/prompts.py), 保证微调与部署分布一致。

2.3 训练配置

四轮均在阿里云百炼（华北 2·北京）网页端以 **QLoRA (4bit 量化)** 训练。LoRA 关键超参在第 2-4 轮被锁定为 rank=16 / alpha=32 / dropout=0.005, 仅学习率、批大小、轮次等按数据规模调整（详见第 3 节）。

2.4 评估协议（「三件套」+ 真实项目）

1. **主基准（569 detect + 29 domain）**：detect 切片报 recall / precision / f1 / cwe_acc；domain 切片报 confirm_recall / fpr / accuracy；
2. **18 条 triage 探针**：含完整可触发代码，Semgrep 必命中，用于精准测 triage 层的 Confirm/Reject 判别（GT 与误报过滤能力）；
3. **42 条真实项目验证（第 4 轮新增）**：35 条 triage 全 Reject + 7 条 detect 全安全，核心指标为真实代码上的 FPR。

3 四轮训练历程

3.1 第一轮：双任务初次微调（建立基线）

目标：在公共 Python 漏洞数据 + 领域密码数据上做首次领域适配，跑通双任务 SFT 全链路。

数据：detect 2406 + triage 132 = 2538 条。

关键超参：LoRA rank=8, lr 1e-4。

结果（作为后续各轮的对照基线）：

- detect：cwe_acc **0.796**, f1 **0.656**；
- domain：confirm_recall **0.357**；
- 18 探针：confirm_recall **0.917**、fpr **0.667**、accuracy **0.722**。

第一轮模型在通用检测上可用，但 triage 层对「非安全用途的弱原语」（生产代码用 MD5 做变更检测 / 缓存键、SHA-1 一致性分片、random 退避抖动等）普遍误判为 Confirm，fpr 高达 0.667——这是第二轮的主攻方向。

3.2 第二轮：triage 增量续训（灾难性遗忘）

目标：仅对 triage 层补 54 条针对弱点的增量样本，压降 fpr。

数据：54 条（28 Confirm + 26 Reject），只含 triage 任务，覆盖 10 条规则。

关键超参：batch 8, lr 1e-4, 3 epochs, LoRA rank16/alpha32/dropout 0.05, max_length 1024。

结果：

- 探针（主攻点）✓ fpr 0.667 → **0.000**, accuracy 0.722 → **0.944**；
- detect ✗ cwe_acc 0.796 → **0.433**（343/569 条 CWE 预测偏移，CWE-321/338 凭空出现 25/23 条）；
- domain ✗ confirm_recall 0.357 → **0.000**（全 Reject，过度纠偏）。

结论：只喂增量样本的续训造成灾难性干扰——triage 指标上去了，detect 与 domain 全崩。教训成为后续决策的核心约束：续训只喂增量样本会遗忘既有任务。

3.3 第三轮：全量合并重训（能力恢复）

目标：放弃续训，改为**从基座**用全量合并数据一次性重训，同时保住 detect 与修复后的 triage。

数据：2595条 = detect 2406 + triage 132 (R1) + 54 (R2 修补) + 3 (签名/认证修补)。

关键超参：batch 16,lr 1e-4,3 epochs,LoRA rank16/alpha32/dropout 0.005,cosine,max_length 2048。

关键决策：在 build_triage_user 追加 **TRIAGE_PURPOSE_GUIDE** 引导（要求推理 flagged call 输出用途是「安全目的 → Confirm」还是「非安全目的 → Reject」）。同模型无引导 fpr 0.500 → 有引导 fpr **0.000**、confirm_recall 保持 1.000。

结果（成为最终验收模型）：

- detect: recall **0.990** / precision 0.537 / f1 **0.697** / cwe_acc **0.921**;
- domain: confirm_recall **0.929** / fpr 0.067 / accuracy 0.931;
- 18 探针（引导后）：fpr **0.000** / confirm_recall **1.000** / accuracy **1.000**。

遗留问题：detect 层仍**近乎全报**——562/569 判漏洞 (tp=302 / fp=260 / fn=3 / tn=4)，仅 4 真负。precision 0.537 约等于数据漏洞占比 0.536，二元 vulnerable 判定无判别力。根因是 detect 训练负样本全是**非加密的通用 Django 代码** (cwe=None)，模型从未见过「安全的加密代码」。这是第四轮的出发点。

3.4 第四轮：负样本微调 + 真实项目验证（未达预期）

目标：补「非漏洞」负样本，让模型在**加密代码**上学会安全/不安全的决策边界，压降 detect 过报；并用真实密码项目做留出验证。

负样本设计 (detect 任务, vulnerable=false)：

- **A 类 (安全现代密码)：**scrypt/argon2/bcrypt/pbkdf2、AES-GCM+ 随机 nonce、ChaCha20-Poly1305、SHA-3、HKDF、ECDH、secrets/os.urandom、RSA-OAEP、Ed25519 等正确原语；
- **B 类 (弱原语 × 非安全目的)：**MD5/SHA-1/random 用于缓存键、去重、分片、变更检测、退避抖动、测试夹具等；其中 **strong-B**（规则命中但模型须越过规则判定非安全）与 **weak-B**（规则不命中）两类。

两条对比路线（见表 3）：

表 3：第四轮两条训练路线

	微量（续训）	全量（基座重训 50:50）
训练起点	R3 模型	基座
训练数据	77 条负样本	3315 条 (detect 3126 + triage 189)
负样本规模	42 A + 35 B（手写）	+150 正 + 493 负 (1563:1563)
lr / epochs	5e-5 / 2	1e-4 / 3

50:50 扩量的负样本构成：240 条 B strong-B（组合）+ 187 条 A 真实深挖（AST 从 5 个仓库提取）+ 66 条 A 组合模板；回测纪律为「正样本必命中、A 类零命中、strong-B 命中预期规则」，全部通过。

结果（完整记录见 data/round4/eval/RESULTS.md）：

- 全量（50:50）：detect recall 0.984 / precision 0.536 / f1 0.694 / cwe_acc 0.897, fp=260 / tn=4 纹丝不动，与 R3 基本持平、无提升；domain 与探针与 R3 一致；
- 微量（续训）✖：detect recall 0.990 → **0.584**, domain confirm_recall 0.929 → **0.071**——第二轮灾难性遗忘重演且更严重，弃用；
- 真实项目验证（42 条）：detect 7 条安全函数两个模型均仅 4/7；domain 35 条 fpr 0.429（微量）/ 0.571（全量）vs 目标 ≤0.06；最硬的 11 条 passlib legacy-hash 库实现，两模型 11/11 全判 Confirm。

4 结果汇总与横向对比

表 4 汇总四轮在统一指标集上的纵向对比。

表 4: 四轮模型核心指标对照

指标	R1	R2	R3	R4-微量	R4-全量
detect recall	—	—	0.990	0.584	0.984
detect precision	—	—	0.537	0.549	0.536
detect f1	0.656	0.642	0.697	0.566	0.694
detect cwe_acc	0.796	0.433	0.921	0.921	0.897
domain confirm_recall	0.357	0.000	0.929	0.071	0.929
domain fpr	—	—	0.067	0.000	0.067
18 探针 accuracy	0.722	0.944	1.000	0.944	1.000

表 5 给出第四轮新增的真实项目验证结果。

表 5: 第四轮真实项目验证（42 条留出集）

指标	微量	全量	目标
detect 7 条安全函数	4/7	4/7	7/7
domain 35 条 fpr	0.429	0.571	≤0.06
passlib legacy-hash 11 条	0/11	0/11	11/11

5 根因分析

5.1 灾难性遗忘的反复出现

第二轮 (triage 增量 54 条) 与第四轮微量 (负样本增量 77 条) 两次证明: **只喂增量样本的 LoRA 续训会遗忘既有任务**。第四轮更严重 (detect recall $0.990 \rightarrow 0.584$ 、domain confirm_recall $0.929 \rightarrow 0.071$), 因为新增负样本与 R3 训练分布差异大 (大量「安全加密代码」), 小学习率小步数仍不足以稳住旧能力。**结论: 在 QLoRA 微调场景下, 任务/分布变化必须以「全量合并 + 基座重训」承载, 续训只能用于同分布微调。**

5.2 合成负样本未带来泛化

第四轮全量 50:50 扩量中, 合成样本占多数 (456 合成 vs 187 真实)。detect fp=260 / tn=4 与 R3 完全一致, 说明 493 条负样本没有教会模型「安全加密代码 = 非漏洞」。可能原因:

1. **模板记忆而非泛化**: 组合生成的合成负样本模板化, 真实库代码与合成模板差异大, 模型背住了模板而非学到了「安全/不安全」的判别语义;
2. **主基准测不到改动点**: 569 条 detect 主基准以非加密 Django 代码为主 (CWE-89/79/330/259 等), crypto 负样本对它的指标几乎无影响, 因此「持平」测的并非本轮改动点;
3. **负样本类型缺关键一类**: B 类全是「非安全目的」的缓存/去重/分片, 缺「密码库实现 legacy 原语 = 非漏洞」这一类——而真实项目验证恰好专考这个 (passlib 实现 md5_crypt/sha1_crypt 等 legacy 格式, 11/11 全误判)。

5.3 detect 层过报的根因未触及

第三轮已定位: detect 训练负样本全是通用非加密代码, 模型从未见过「安全的加密代码」, 故学到「宁可全报」。第四轮试图补正但失败, 核心原因在于**补进去的负样本仍是合成占多数、且未覆盖真实库实现 legacy 原语的场景**, 模型学到的安全边界与真实部署要判的边界不重合。

6 结论与展望

6.1 结论

1. **全量合并重训 (基座起点) 是本项目唯一稳定可靠的训练范式**: R3 与 R4-全量均以此方式取得 detect cwe_acc ≥ 0.89 、domain confirm_recall 0.929 的稳定结果; 增量续训两次均以灾难性遗忘告终。
2. **triage 层已达实用水平**: 在 TRIAGE_PURPOSE_GUIDE 引导下, 18 探针 fpr=0.000、confirm_recall=1.000、domain fpr=0.067, 误报过滤能力强。
3. **detect 层过报仍未解决**: R4 的合成负样本扩量未奏效, fp=260/tn=4 未动; 真实项目验证两个 R4 模型均未达标 (fpr 0.429–0.571 vs 目标 ≤ 0.06)。
4. **当前可沿用模型为 R3 (...f5d4f1aedd8f)**: R4-全量与其基本等价 (cwe_acc 0.897 vs 0.921 略降), 无提升价值; R4-微量已弃用。

6.2 下一步工作

1. **纯真实负样本重训**：放弃合成扩量，改用「187真实深挖 + 77 手写」的纯真实负样本重训（基座起点），消除模板记忆问题；
2. **新增「库实现 legacy 原语」负样本**：针对真实项目 11 条 passlib legacy-hash 全错的问题，补「密码库/哈希库实现 legacy 格式（md5_crypt、DES、RC4）是兼容所需而非漏洞」这一类负样本，让 detect 学会区分「误用」与「库的兼容实现」；
3. **正负样本配比再平衡**：若继续扩量，按真实漏洞分布（漏洞本就少）设 40:60 或更低，而非强行 50:50；
4. **扩大真实项目验证集**：当前 42 条（5 库）偏小，扩充真实密码库留出集以稳定 FPR 估计；
5. **度量与改动点对齐**：为 detect 过报单独构建**加密代码专属基准**（而非依赖以非加密为主的 569 主基准），使「detect 在加密代码上的 FPR」成为可观测、可归因的指标。

A 模型 ID 与关键文件索引

模型端点（百炼 cn-beijing）：

- 基座：qwen3-4b-instruct-2507
- R1：qwen3-4b-instruct-2507-510facca98f1
- R2：qwen3-4b-instruct-2507-da015253d244
- R3：qwen3-4b-instruct-2507-f5d4f1aedd8f
- R4-微量：qwen3-4b-instruct-2507-d3eaeead171b
- R4-全量：qwen3-4b-instruct-2507-59e3a576c1e2

关键文件：

- data/round2/ROUND2_GUIDE.md：第二轮数据与续训指引；
- data/round3/ROUND3_GUIDE.md：第三轮全量重训指引；
- data/round3/eval/ACCEPTANCE.md：第三轮验收记录（含 round1-3 对照）；
- data/round4/ROUND4_GUIDE.md：第四轮负样本设计与 50:50 扩量；
- data/round4/eval/RESULTS.md：第四轮完整评测记录；
- crypto-ai-auditor-roadmap.md：项目推进计划 v2（数据快照、决策日志、评估协议）。